

An Online Payment Service Report

Presentation Layer

This section was fully implemented.

- The project consists of 13 HTML templates, split into three main categories:
 - Registration/login, admin, and general payapp interface
 - A base template was used by all templates to maintain consistency
- Users can:
 - View all their transactions via the 'View Payment History' tab
 - Make direct payments to other registered users via the 'Make a Payment' tab
 - Request payments from registered users via the 'Request Payment' tab
 - View all their request history via the 'Request History' tab
 - View notifications on their homepage for 3 most recent payments, and any requests they have received
- Admin can:
 - View all user accounts
 - View all payment transactions
 - View all payment requests
 - Register new administrators
- All templates are connected to their respective view files, with URL routing defined in 'webapps2026/urls.py' file.
- Data input is cleaned and validated in the respective 'forms.py' files, using 'EmailField', 'CharField', 'ChoiceField', and 'DecimalField' as and when required
- CSRF tokens are included in the 'POST' forms in templates
- Users can only view user templates, whereas admins can also see admin templates
- Bootstrap was used for styling, with crispy forms used on pages with forms
- Pages showing tables include borders and spaces between the tables, making it easier to read

Business Logic Layer

This section was fully implemented.

- All functions in 'views.py' files either redirect or render the user to the necessary page, such as 'home' or 'request history'
- The 'home' view allows users to view their account balance, currency, and provides notifications for any requests received and their three most recent direct payments
- Payment and request history pages display all the users' payment and request histories, respectively
 - Request history also allows users to accept or reject received requests, and shows their current statuses (accepted, pending, rejected)
- Direct payment view allows users to send payments by inputting their desired recipient's email, and the amount of their own currency they want to send
- Request payment view allows users to request payments in their own currency, and is sent to the user of the email they entered
- Admins have four views, which are available from the admin home view
 - View all user accounts, view all payments, view all requests, register admin

ACID:

- ACID is maintained using 'transaction.atomic()' during:
 - Registration ensures the account and user are created simultaneously
 - Direct payments ensure that both sender and receiver have their balances updated together
 - Request payments ensures request status is uniform between accounts, and when accepted, both account balances are correctly updated, with updated timestamps
- 'select_for_update()' is used to ensure the selected rows can only be modified by that operation
- Checks occur throughout to ensure invalid transfers cannot happen, such as:
 - Users entering their own email
 - Sending\requesting negative amounts
 - Sending or requesting amounts where the sender has insufficient funds
 - Status checks ensure requests can only happen once, no duplicates

Data Access Layer

This section was fully implemented.

- The database is named 'webapps.db', as required, through updating the name in 'settings.py'
 - The database is SQLite RDBMS
- Models implemented are 'UserAccount', 'User', 'DirectPayment', and 'RequestPayment'
- UserAccount:
 - Stores the user's chosen currency from the three available options, and stores their current balance, initialised to 500 GBP or its conversion to USD/EUR upon creation
- DirectPayment:
 - Linked to the sender and receiver through foreign keys to User
 - Stores sender and receiver currencies, amount sent and received, and the time it was created
- RequestPayment:
 - Linked to the requester and requested from through foreign keys
 - Stores both users' currencies, the amount to send and receive, the request status, and the creation time
- Relationships:
 - One User has one 'UserAccount', can send and receive many 'DirectPayments', and can send and receive many 'RequestPayments'
- Security:
 - No raw SQL is used
 - Data access is handled through the models
 - The database is generated through migrations

Security Layer

This section was fully implemented.

Authentication Functionality:

- Both users and admins can successfully log out of the application
- User registration, login, and logout are successfully implemented, with unique usernames and emails to prevent ambiguity when making/requesting payments

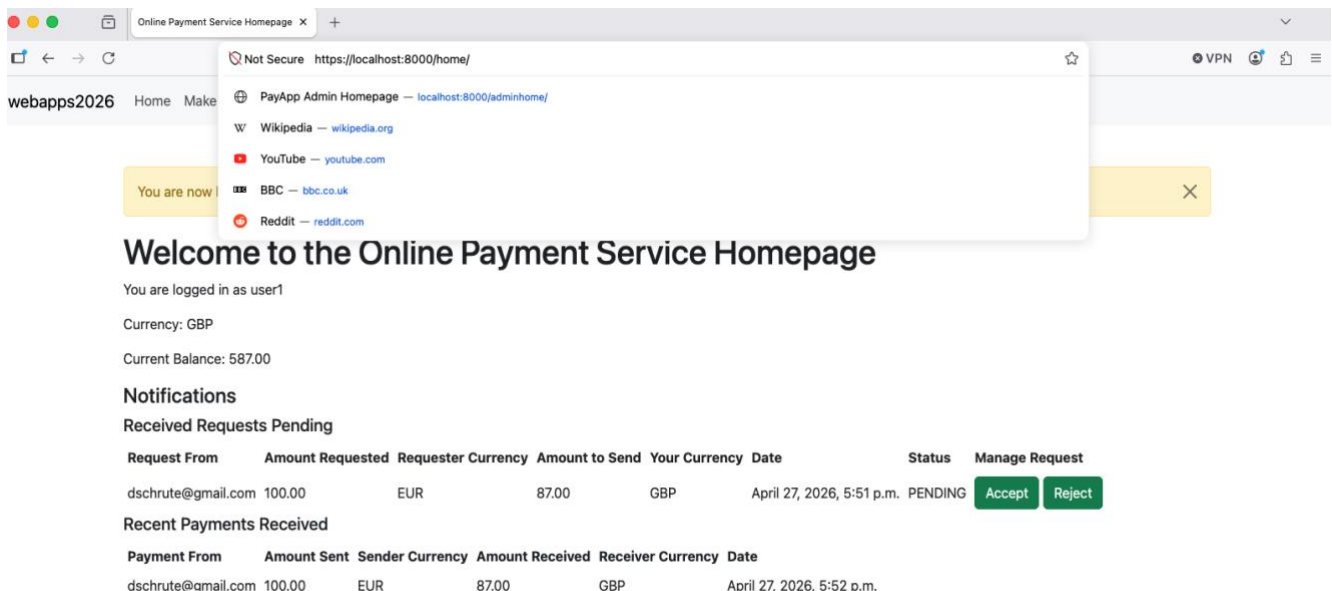
- New admin accounts can only be registered by an existing admin through the restricted admin-only page, 'registeradmin.html'
- An admin is automatically registered when activating the models
 - Username: admin1, password: admin1, email: admin1@admin1.com, default: 500 GBP

Access Control:

- Access control is primarily enforced through '@login_required' on necessary functions in all 'views.py' files, with superuser checks for admin pages, and 'base.html' ensuring 'user.is_authenticated' is true
- Users are only able to view their own data and information
- Admin pages are restricted to only admins, and can only be viewed by admins on the navbar
 - Enforced through 'is_superuser' checks
 - Users cannot bypass by entering URLs for admin pages
 - Hidden from normal users by 'base.html'
- Admin can view all standard user pages, as well as admin-only pages, which give access to all user information

HTTPS Functionality:

- HTTPS is enabled using a self-signed certificate and locally created key, and can be run using:
 - 'python manage.py runserver_plus localhost:8000 --cert-file webapps2026.crt --key-file webapps2026.key'
- Works on Firefox but not Chrome, potentially due to the different security policies around self-signed certificates
- As it is a self-signed certificate, it isn't fully trusted by the browser, which is why it says, 'Not Secure', even though it is HTTPS



Running the application via HTTPS on Firefox

Web Security Protection Functionality:

- XSS is protected via Django's built-in protection:
 - Templates automatically escape specific characters
- CSRF is enforced through POST forms having '{% csrf_token %}', '@csrf_protect' in some view functions, and "django.middleware.csrf.CsrfViewMiddleware" in 'settings.py's' MIDDLEWARE

- SQL Injection is protected against through no raw SQL usage, and through Django's automatic query parameterisation
- Clickjacking is protected through "django.middleware.clickjacking.XFrameOptionsMiddleware" in 'settings.py's' MIDDLEWARE

Initial Admin Registration:

- An initial admin account is automatically created after migrations if it does not already exist

Web Services

This section was fully implemented.

- Successful currency conversion was implemented in the currencyconversion app, using a RESTful service, with endpoint:
 - '/webapps2026/conversion/{currency1}/{currency2}/{amount_of_currency1}'
 - Added two assignments to get the protocol (HTTP or HTTPS) and the webhost (localhost or 127.0.0.1), as it couldn't be hardcoded to HTTP once HTTPS was implemented
- It only responds to GET requests, accepting source and destination currencies, as well as the source amount of currency
- It returns the source and destination currencies, the conversion rate, the amount of source currency, and the converted amount of currency
- 'HTTP_400_BAD_REQUEST' is returned if one or both currencies are invalid, the source amount is invalid, or the amount is negative
- 'HTTP_200_OK' is returned if conversion is successful
- It is used by:
 - Registration to provide the correct initial amount of money based on the currency chosen
 - Direct payments in case the payment is between two different currencies
 - Request payments to calculate the amount to send and receive if the currencies are different

127.0.0.1:8000/webapps2026/conversion/USD/GBP/10.96/

Django REST framework
Log In

Currency Conversion
OPTIONS GET

GET /webapps2026/conversion/USD/GBP/10.96/

```

HTTP 200 OK
Allow: GET, HEAD, OPTIONS
Content-Type: application/json
Vary: Accept

{
  "currency1": "USD",
  "currency2": "GBP",
  "conversion_rate": "0.74",
  "amount_of_currency1": "10.96",
  "converted_amount": "8.11"
}

```

Currency Conversion returning a successful JSON response on the REST endpoint

Deployment on Amazon AWS

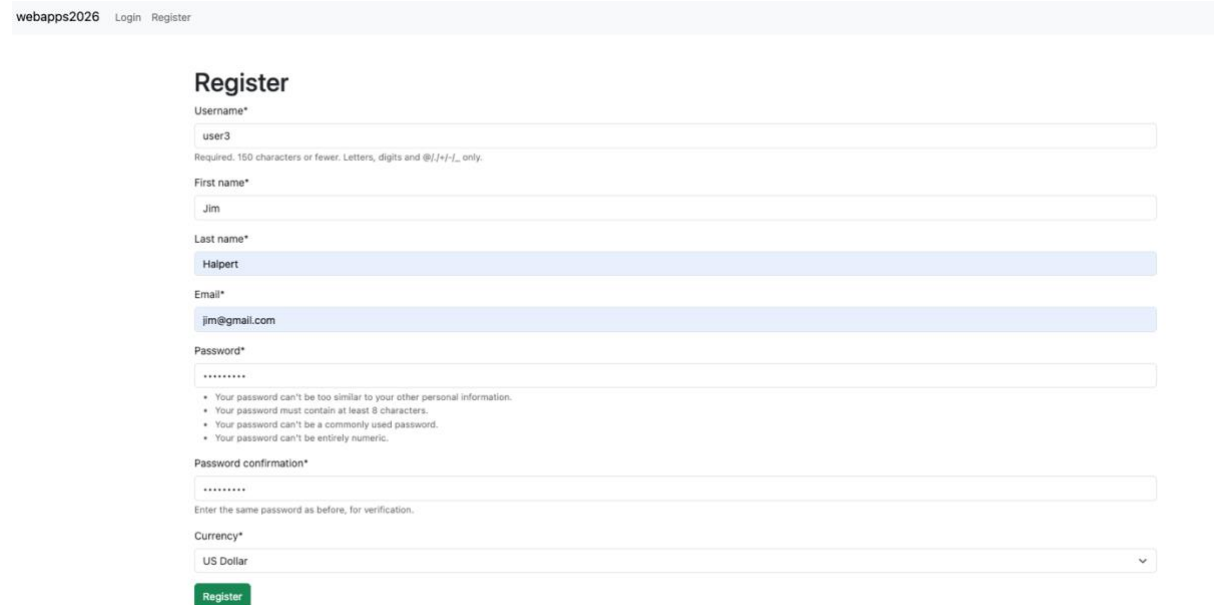
This section was not implemented.

- AWS deployment was not completed
- The application could not be deployed and successfully run as an EC2 instance

User Manual

Authentication

1. Registration Page

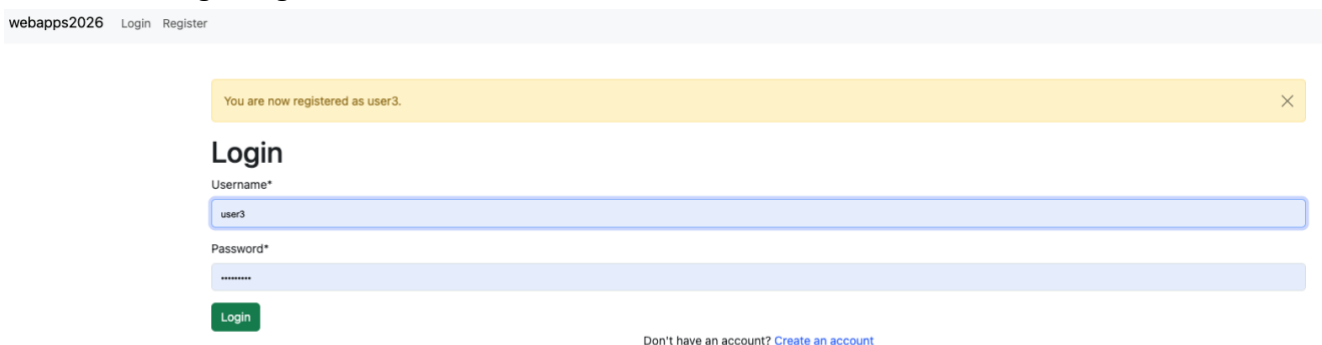


The screenshot shows the 'Register' page of a web application. At the top left, there is a navigation bar with the text 'webapps2026' and links for 'Login' and 'Register'. The main heading is 'Register'. Below it, there are several input fields: 'Username*' with the value 'user3', 'First name*' with the value 'Jim', 'Last name*' with the value 'Halpert', 'Email*' with the value 'jim@gmail.com', 'Password*' (masked with dots), and 'Password confirmation*' (also masked with dots). Below the password fields, there are four bullet points providing password requirements. At the bottom, there is a 'Currency*' dropdown menu set to 'US Dollar' and a green 'Register' button.

Figure 1: Registration page, where you can register as a user.

Figure 1 shows the registration page, with a user attempting to register an account. They have chosen their currency as USD, via the dropdown box, meaning their currency will be 500 GBP x its USD_conversion_rate. When happy, they will press the green 'Register' button.

2. Login Page



The screenshot shows the 'Login' page of a web application. At the top left, there is a navigation bar with the text 'webapps2026' and links for 'Login' and 'Register'. A yellow banner at the top says 'You are now registered as user3.' with a close button. The main heading is 'Login'. Below it, there are two input fields: 'Username*' with the value 'user3' and 'Password*' (masked with dots). Below the password field, there is a green 'Login' button. At the bottom right, there is a link that says 'Don't have an account? [Create an account](#)'.

Figure 2: The login page, with a successful registration message displayed.

Upon registering, they will be redirected to the login page, where they are able to login by pressing the green 'Login' button. A success message is also displayed, informing them that their account is registered. Here, they are also able to create another account, using the respective link at the bottom of the form.

3. Home Page

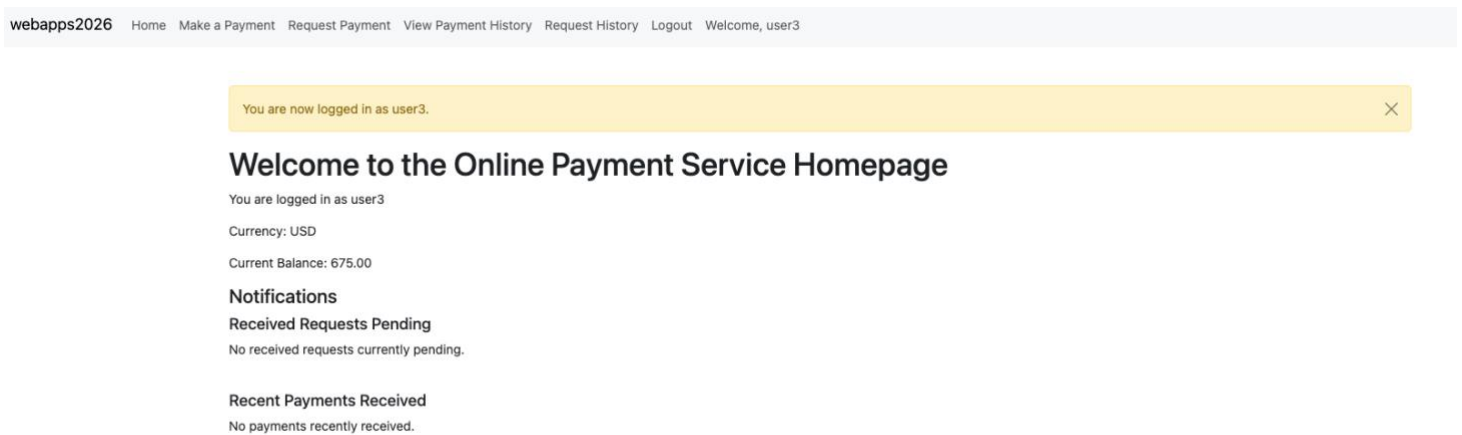


Figure 3: The homepage viewed once logged in, displaying their currency, balance, and any notifications.

Once logged in, you are directed to this homepage, with a successful 'login' message displayed at the top, which can be removed by pressing 'x' on the right. The user's balance was successfully converted to its USD equivalent of 500 GBP. They currently have no notifications as their account is new, so they haven't received any requests or payments. They can navigate to different pages using the navbar at the top.

User Functions

4. 'Make a Payment' Page

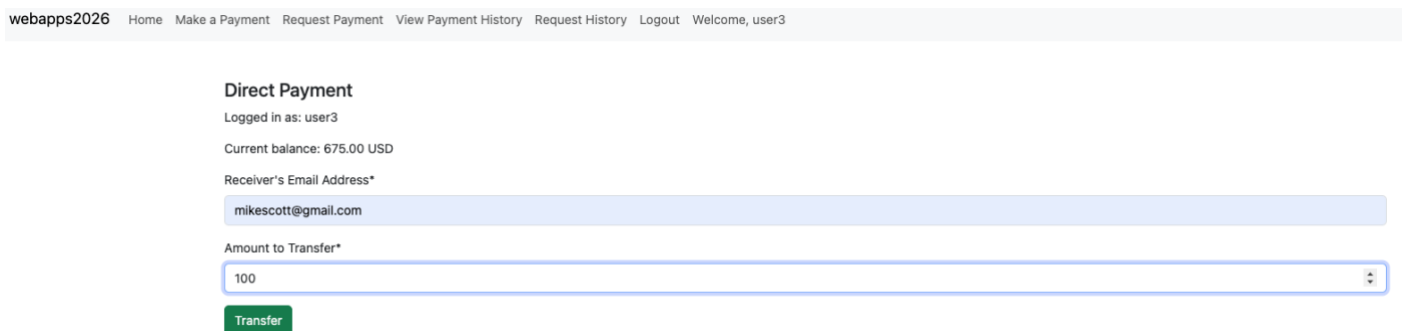


Figure 4: 'Make a Payment' page displayed, showing the user's balance and currency, and the payment form.

The user decided to navigate to the 'Make a Payment' page via the navbar, where they are sending 100 USD to 'mikescott@gmail.com'. To send someone money, you must enter their email to identify them. The page shows who they are logged in as and their current balance.

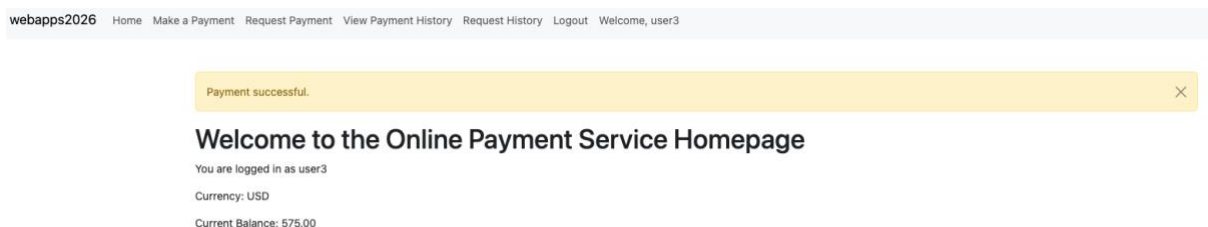


Figure 5: Redirect to homepage, displaying their updated balance and success message.

Upon pressing 'Transfer', they will be redirected to the homepage, with a 'Payment successful' success message displayed at the top. Their updated balance is also displayed, showing 575.00 now instead of 675.00, as they sent 100 USD. There is no new notifications either, as they sent, not received, a payment.

5. 'Request Payment' Page

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, user3

Request Payment

Logged in as: user3

Current balance: 575.00 USD

Request-Receiver's Email Address*

dschrute@gmail.com

Amount to Request*

100

Request

Figure 6: 'Request Payment' page, displaying current balance and the completed form.

The user has navigated to the 'Request Payment' page using the navbar, and has filled in the form, requesting 100 USD from 'dschrute@gmail.com'. Again, the email address is used as the identifier. Upon sending the request, they will be redirected to the homepage if successful, with an unchanged balance.

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, user3

Payment request successfully sent. X

Welcome to the Online Payment Service Homepage

You are logged in as user3

Currency: USD

Current Balance: 575.00

Figure 7: Redirect to the homepage, with a success message displayed.

Successfully redirected to the homepage with a success message displayed at the top, meaning the request was also sent. If any part had failed, the user would have been redirected to an empty request form, with the error message displayed at the top. This is also true for any errors in 'Direct Payment'. They decided to log out after this by pressing 'Logout' on the navbar.

6. 'View Payment History' Page

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, user1

Payment History

Logged in as: user1

Current balance: 574.00 GBP

Payment To	Amount Sent	Sender Currency	Amount Received	Receiver Currency	Date
dschrute@gmail.com	87.00	GBP	100.00	EUR	April 28, 2026, 9:52 a.m.

Payment From	Amount Sent	Sender Currency	Amount Received	Receiver Currency	Date
jim@gmail.com	100.00	USD	74.00	GBP	April 28, 2026, 10:44 a.m.
dschrute@gmail.com	100.00	EUR	87.00	GBP	April 27, 2026, 5:52 p.m.

Figure 8: 'View Payment History' Page, seen by 'user1'.

Logging in as 'user1', and viewing the 'View Payment History' tab from the navbar, you can see their payment history. This user has been registered for longer, so has had a couple more payments. One table is for 'Sent Payments', and the other for 'Received Payments'. Each table shows who it was from/to, the amount sent and its currency, the amount received in its respective currency, and the date of the transaction. You can see the payment from 'user3', created above, has successfully come through, with the amount received being 74.00 GBP, which is equivalent to the 100 USD sent.

7. 'Request History' Page

webapps2026	Home	Make a Payment	Request Payment	View Payment History	Request History	Logout	Welcome, user2
-------------	------	----------------	-----------------	----------------------	-----------------	--------	----------------

Request History							
Logged in as: user2							
Current balance: 575.00 EUR							
Request To	Amount Requested	Requester Currency	Amount To Send	Requested From's Currency	Date	Status	
mikescott@gmail.com	100.00	EUR	87.00	GBP	April 27, 2026, 5:51 p.m.	ACCEPTED	

Request From	Amount Requested	Requester Currency	Amount to Send	Your Currency	Date	Status	Manage Request
jim@gmail.com	100.00	USD	86.00	EUR	April 28, 2026, 10:57 a.m.	PENDING	<button>Accept</button> <button>Reject</button>
mikescott@gmail.com	100.00	GBP	115.00	EUR	April 28, 2026, 9:53 a.m.	REJECTED	No Managing Available

Figure 9: 'Request History' page, as seen by 'user2'.

Logging in as 'user2' (dschrute@gmail.com) and navigating to the 'Request History' page via the navbar, we can see a similar table as before, but this time showing requests. The tables are the same, aside from extra columns 'Status', showing the request status, and 'Manage Request', displayed on received requests, where you can choose to 'Accept' or 'Decline' the request. You can see that the previously sent request has been successfully received and is awaiting a decision.

8. Notifications on Homepage

webapps2026	Home	Make a Payment	Request Payment	View Payment History	Request History	Logout	Welcome, user2
-------------	------	----------------	-----------------	----------------------	-----------------	--------	----------------

Welcome to the Online Payment Service Homepage							
You are logged in as user2							
Currency: EUR							
Current Balance: 575.00							
Notifications							
Received Requests Pending							
Request From	Amount Requested	Requester Currency	Amount to Send	Your Currency	Date	Status	Manage Request
jim@gmail.com	100.00	USD	86.00	EUR	April 28, 2026, 10:57 a.m.	PENDING	<button>Accept</button> <button>Reject</button>

Recent Payments Received					
Payment From	Amount Sent	Sender Currency	Amount Received	Receiver Currency	Date
mikescott@gmail.com	87.00	GBP	100.00	EUR	April 28, 2026, 9:52 a.m.

Figure 10: Homepage displaying notifications.

webapps2026	Home	Make a Payment	Request Payment	View Payment History	Request History	Logout	Welcome, user2
-------------	------	----------------	-----------------	----------------------	-----------------	--------	----------------

Successfully Accepted Requested Payment. ×							
Request History							
Logged in as: user2							
Current balance: 489.00 EUR							
Request To	Amount Requested	Requester Currency	Amount To Send	Requested From's Currency	Date	Status	
mikescott@gmail.com	100.00	EUR	87.00	GBP	April 27, 2026, 5:51 p.m.	ACCEPTED	

Request From	Amount Requested	Requester Currency	Amount to Send	Your Currency	Date	Status	Manage Request
jim@gmail.com	100.00	USD	86.00	EUR	April 28, 2026, 10:57 a.m.	ACCEPTED	No Managing Available
mikescott@gmail.com	100.00	GBP	115.00	EUR	April 28, 2026, 9:53 a.m.	REJECTED	No Managing Available

Figure 11: Accepting the payment request through the homepage, showing a success message and updated balance.

Figure 10 shows notifications on the homepage: 'Received Requests Pending' and up to the three most recent 'Recent Payments Received'. The user is alerted to new payments and requests received. They can manage the payment request from the homepage, and upon acceptance or rejection, it redirects them to 'Request History', displays a success message, and updates their balance if necessary. From here, they can also manage any other received requests.

Admin Functions

9. Admin's Home Page

Welcome to the PayApp Admin Homepage

You are logged in as admin1

- [View all user accounts](#)
- [View all payments](#)
- [View all payment requests](#)
- [Register a new admin](#)

Figure 12: Admin Homepage, for admins only, where they can access admin views.

Here is the admin's homepage, which can be accessed only by admins using the 'Admin Homepage' tab in the navbar. This is only visible to 'superusers', so admins and normal accounts cannot see it, as shown in previous navbars. From here, admins can navigate to the four different admin-only views.

10. Admin's 'View all User Accounts' Page

[Return to Admin Home](#)

User Accounts

Logged in as: admin1

Username	Email	Currency	Balance
admin1	admin1@admin1.com	GBP	500.00
user1	mikescott@gmail.com	GBP	500.00
user2	dschrute@gmail.com	EUR	575.00
user3	jim@gmail.com	USD	675.00

Figure 13: Admin page 'View all user accounts'.

Admins can view all user accounts registered. The accounts shown are all newly created to show the unchanged initial balances after conversion. They can return to the admin homepage using either the navbar or the button above the header.

11. Admin's 'View all Payments' Page

[Return to Admin Home](#)

Payments

Logged in as: admin1

Sender	Sender Currency	Amount Sent	Receiver	Receiver Currency	Amount Received	Date
mikescott@gmail.com	GBP	87.00	dschrute@gmail.com	EUR	100.00	April 28, 2026, 4:34 p.m.
dschrute@gmail.com	EUR	86.00	jim@gmail.com	USD	100.00	April 28, 2026, 4:34 p.m.
dschrute@gmail.com	EUR	100.00	mikescott@gmail.com	GBP	87.00	April 28, 2026, 4:34 p.m.
jim@gmail.com	USD	100.00	mikescott@gmail.com	GBP	74.00	April 28, 2026, 4:32 p.m.

Figure 14: Admin 'View all payments' page, showing all user transactions.

Here, admins can view all user payments, so all four in this instance. It shows the sender, receiver, respective amounts in their currencies, and the time of the transaction.

12. Admin's View all Payment Requests' Page

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, admin1 Admin Homepage

[Return to Admin Home](#)

Requests

Logged in as: admin1

Request To	Amount Requested	Requester Currency	Amount To Send	Requested From's Currency	Date	Status
jim@gmail.com	50.00	USD	37.00	GBP	April 28, 2026, 4:37 p.m.	PENDING
mikescott@gmail.com	100.00	GBP	135.00	USD	April 28, 2026, 4:37 p.m.	REJECTED
dschrute@gmail.com	100.00	EUR	87.00	GBP	April 28, 2026, 4:34 p.m.	ACCEPTED
jim@gmail.com	100.00	USD	86.00	EUR	April 28, 2026, 4:33 p.m.	ACCEPTED

Figure 15: Admin's 'View all requests' page, where they can view all requests and the status.

Admins 'View all payment requests' page, where they can view all requests that have been sent. They can see who the request is to, how much is requested in their currency, how much needs to be sent in the sender's currency, the date of request, and the status, so 'ACCEPTED', 'PENDING', or 'REJECTED'.

13. Admin's 'Register Admin' Page

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, admin1 Admin Homepage

[Return to Admin Home](#)

Register Admin

Username*

admin2

Required. 150 characters or fewer. Letters, digits and @/./+/-/_ only.

First name*

admin

Last name*

2

Email*

admin2@admin2.com

Password*

.....

- Your password can't be too similar to your other personal information.
- Your password must contain at least 8 characters.
- Your password can't be a commonly used password.
- Your password can't be entirely numeric.

Password confirmation*

.....

Enter the same password as before, for verification.

Currency*

US Dollar

[Register Admin](#)

Figure 16: Registering a new admin whilst logged in as an admin.

webapps2026 Home Make a Payment Request Payment View Payment History Request History Logout Welcome, admin2 Admin Homepage

You are now logged in as admin2.

Welcome to the Online Payment Service Homepage

You are logged in as admin2

Currency: USD

Current Balance: 675.00

Notifications

Received Requests Pending

No received requests currently pending.

Recent Payments Received

No payments recently received.

Figure 17: Logging in as the new admin account, with the 'Admin Homepage' visible and correctly converted balance.

Figure 16 shows 'admin1' registering a new admin account, using the 'Register a new admin' page. The page can only be accessed by a superuser (admin account), and the account created will have admin privileges. It works the same as standard registration, except the user will be redirected back to the 'Admin Homepage' in their current account, and will have to log out to login as the newly registered admin.

Figure 17 then shows the new admin account having logged in, where you can see their balance has been correctly converted, and they have the 'Admin Homepage' tab visible in the navbar.